

Guía Metodológica de la Encuesta TRIKE

Diseño, aplicación e interpretación de resultados

1. Propósito de la encuesta

La presente encuesta tiene como objetivo medir, de manera estructurada y comparativa, el grado de desarrollo de prácticas de ciberseguridad en organizaciones españolas bajo el prisma TRIKE: Threat, Risk, Impact, Knowledge y Evaluation. [web:16][web:20][web:23][web:14]

Se persigue:

1. Obtener una línea base de madurez en gestión de amenazas y riesgos alineada con NIS2, el marco nacional y las recomendaciones de organismos europeos. [web:17][web:20][web:23]
2. Identificar brechas entre las expectativas regulatorias y la realidad de las prácticas organizativas. [web:18][web:23]
3. Facilitar comparativas sectoriales y territoriales (benchmarking) útiles para políticas públicas, estrategias corporativas y priorización de inversiones. [web:16][web:22]

2. Marco conceptual: TRIKE y entorno regulatorio

El marco TRIKE se utiliza aquí como prisma estructurador, aun cuando las organizaciones encuestadas no utilicen TRIKE explícitamente. [web:14][web:21]

Cada dimensión se vincula con obligaciones de gestión del riesgo y resiliencia recogidas en NIS2, la transposición española y guías técnicas de ENISA. [web:17][web:20][web:23]

- Threat: exposición a amenazas y madurez en modelado de amenazas.
- Risk: sistemas de gestión y cuantificación del riesgo.
- Impact: capacidad de medir y clasificar consecuencias de incidentes.
- Knowledge: inteligencia, formación, cultura y aprendizaje organizativo.
- Evaluation: mecanismos de revisión, auditoría y mejora continua.

3. Población objetivo y muestreo

La encuesta está pensada para:

- Organizaciones cubiertas por NIS2 (entidades esenciales e importantes) y su transposición en España. [web:17][web:20]
- Organizaciones no cubiertas pero que adopten estándares de referencia (ENS, ISO 27001, etc.).
- Pymes con rol relevante en cadenas de suministro críticas o servicios digitales.

Se recomienda:

- Un muestreo estratificado por sector (sanidad, energía, administración pública, etc.), tamaño y rol regulatorio.
- Garantizar un mínimo de respuestas por estrato para permitir análisis comparativos robustos.

4. Instrumento de medida: lógica de secciones

La encuesta recoge información en siete bloques:

4. Información general: permite la segmentación por tipo, tamaño, sector y alcance.
5. Threat: preguntas 1.x orientadas a catálogo, modelado de amenazas y uso de métricas.
6. Risk: preguntas 2.x sobre marcos de gestión, cuantificación y ciberseguro.
7. Impact: preguntas 3.x sobre medición de impacto económico, operativo, reputacional y sistémico.
8. Knowledge: preguntas 4.x sobre inteligencia de amenazas, lecciones aprendidas y talento.
9. Evaluation: preguntas 5.x sobre evaluación de controles, auditorías y cumplimiento normativo.
10. Métricas, IGM y ROI: preguntas 6.x sobre cuadros de mando y visión del retorno de la inversión.

Este diseño permite:

- Analizar cada dimensión TRIKE por separado.
- Construir índices compuestos de madurez y prácticas (ver sección 7).
- Realizar cruces con variables estructurales (sector, tamaño, regulación aplicable).

5. Tipo de respuestas y escalas

La mayoría de preguntas utilizan:

- Opción única nominal (p.ej. tipo de organización).
- Escalas ordinales de desarrollo/madurez (de “no existe” a “sistémico”).
- Selección múltiple para capturar diversidad de prácticas.

Recomendaciones:

- Mantener la codificación interna de respuestas (p.ej. 0–4) para permitir cálculo de índices.
- Evitar alterar los enunciados sin revisar la coherencia con el mapeo normativo y los indicadores derivados.

6. Procedimiento de aplicación

6.1 Modalidad

- Preferentemente online, mediante formulario seguro accesible solo con invitación.
- Posibilidad de entrevistas asistidas para organizaciones con menor madurez digital.

6.2 Perfil del respondente

Idealmente:

- CISO, CIO, responsable de seguridad o de riesgos.
- En su defecto, alguien con visión transversal de sistemas, operaciones y cumplimiento normativo.

Se recomienda:

- Validar internamente las respuestas con al menos otra persona clave (p.ej. responsable de cumplimiento, de negocio o de continuidad de negocio).

6.3 Duración

La duración estimada es de 20 a 35 minutos, dependiendo del nivel de detalle y reflexión.

Como regla de bolsillo: “si tarda menos de diez minutos, probablemente ha sido demasiado optimista; si tarda más de una hora, probablemente lo está haciendo bien pero sufrirá”.

7. Construcción de índices e indicadores

La encuesta permite construir, entre otros, los siguientes índices:

- Índice TRIKE de Madurez (IGM): combinación ponderada de puntuaciones en Threat, Risk, Impact, Knowledge y Evaluation.
- Índice de Amenaza Percibida y Gestionada (T): mide prácticas de identificación, modelado y uso de métricas de amenazas.
- Índice de Riesgo y Cuantificación (R): captura la formalización del marco, la cuantificación y la vinculación a decisiones.
- Índice de Impacto (I): refleja la capacidad de medir impacto económico, operativo, reputacional y sistémico.
- Índice de Conocimiento (K): sintetiza inteligencia de amenazas, formación, lecciones aprendidas y cultura.
- Índice de Evaluación (E): analiza revisión de modelos, auditorías y alineamiento regulatorio.

En la plantilla de Excel asociada se propone una codificación numérica de cada respuesta (0–4) y una ponderación ajustable para cada grupo de preguntas. (Véase `e_plantilla_excel_igm_roi.md`.)

8. Enfoque normativo y comparativo

El diseño se alinea con:

- Requisitos de gestión de riesgos y gobernanza de NIS2, según guía técnica de ENISA. [web:23]
- Anteproyecto de Ley de Coordinación y Gobernanza de la Ciberseguridad en España, incluyendo la creación del CNCS. [web:20]
- Prácticas recomendadas de threat modeling y métricas propuestas en documentos de ISACA. [web:14][web:21][web:28]

Esto permite:

- Mapear cada pregunta a obligaciones o recomendaciones normativas.
- Utilizar los resultados como evidencia para planes de acción, roadmap de cumplimiento o para auditorías.

9. Interpretación de resultados

Se recomienda:

- No usar los índices como arma arrojadiza, sino como espejo estratégico.
- Situar los resultados en contexto (sector, tamaño, regulación aplicable).
- Evitar comparaciones simplistas (“somos mejor/peor que”) y centrarse en brechas y prioridades.

Un uso maduro del instrumento consiste en:

- Identificar 3–5 áreas prioritarias de mejora por dimensión TRIKE.
- Vincular esas áreas con medidas concretas, responsables y plazos.
- Repetir la encuesta periódicamente (p.ej. cada 18–24 meses) para observar la evolución.

10. Consideraciones éticas y de confidencialidad

- Garantizar el anonimato en informes agregados, salvo acuerdo explícito.
- Evitar recopilar datos innecesarios o excesivamente sensibles.
- Aplicar buenas prácticas de protección de datos y transparencia en el uso de la información recolectada.

10+1. Nota final

Esta encuesta no es un test de pureza.

No pretende coronar al “mejor alumno” en ciberseguridad, sino ayudar a todos a dejar de copiar en silencio del vecino y empezar a entender por qué algunos exámenes –los de la realidad– salen mejor que otros.